

A bug bounty report template with findings.

- **Bug Bounty Hunting**

Bug bounty hunting is the practice of finding security vulnerabilities in websites or apps, and reporting them responsibly to the company in exchange for rewards (money, swag, etc.).

- **Responsible Disclosure & Ethical Hacking**

Responsible disclosure means reporting bugs only to the website owner or platform securely, without exploiting the bug. Ethical hacking means hacking with permission, legally and morally correct.

1. Bug Bounty Platform Joined

- **Platform Name:** Bugcrowd
 - **Joined As:** Security Researcher
-

2. Target Program Selected

- **Program Name:** Mastercard Public Bug Bounty
 - **Program Type:** Public
 - **Scope Rating:** 3 out of 4
 - **Safe Harbor:** Partial Safe Harbor
 - **Testing Status:** In Progress (Since August 01, 2016)
 - **Category:** Finance / Payments Network
-

3. Program Details

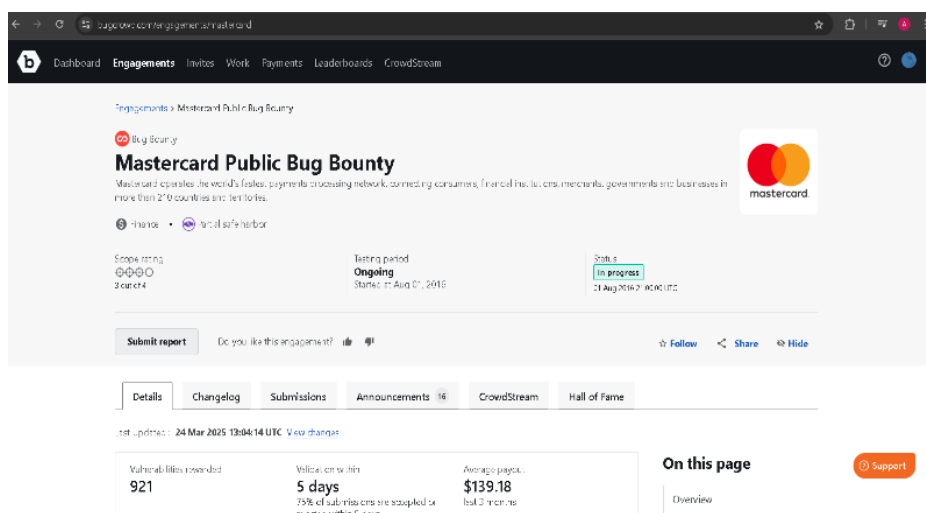
Field	Value
Vulnerabilities Rewarded	921+
Average Validation Time	5 Days
Average Payout	\$139.18 (last 3 months)
Submission Method	Submit report via Bugcrowd dashboard
Target Type	Web applications & related services

4. Why This Program Was Chosen?

Mastercard is a global leader in digital payments. Testing this program offers:

- Exposure to a real-world financial ecosystem.
 - A high-scope environment with decent rewards.
 - Experience with ethical hacking in regulated industries.
-

Interface of vulnerable website in a legal bug bounty platform(Bugcrowd)



Public target

Public Other Targets

✓ In scope

P1 \$700 – \$2500

P2 \$300 – \$1000

P3 \$150 – \$500

P4 \$50 – \$150

If you find a security flaw on a target that is outside of the scope mentioned under 'Private' and 'Public' Target but clearly affects Mastercard, you can report it at "Public Other" Program.

Also, findings related to Mergers and Acquisitions (M&A) could be considered under 'Public Others' category.

Vendor based application URLs/3rd party URLs:

Any Partner Sites of Mastercard (e.g. www.mastercard-*.com) are mainly marketing based sites that are not part of the core Mastercard domains (.mastercard.com) and are managed by hosting vendor companies. Vulnerabilities on these assets will be awarded lower bounties:

P1	P2	P3	P4
\$700	\$300	\$150	\$50

The reward amount for submissions reported for any lower environment (such as stage, dev, test, sandbox, or UAT) of third-party developed (vendor) applications will be 50% of the standard amount mentioned in above table.

give.mastercard.com is a vendor based application and bounty payouts will be according to this table.

Pay-outs for Subdomain Takeover:

vulnerable website in a legal bug bounty platform (Bugcrowd)

In-scope & Out of scope Vulnerabilities:

In-scope focused vulnerabilities:

- Cross Site Scripting (XSS)
- Cross Site Request Forgery (CSRF)
- Insecure direct object references
- Injection Vulnerabilities
- Authentication Vulnerabilities
- Server-side Code Execution
- Privilege Escalation
- Significant Security Misconfiguration (when not caused by user)
- Any out of the box issues which could lead to compromise or leakage of data and directly affect the

Out of Scope vulnerabilities specifically excluded from the bounty:

- Pivoting, scanning, and vulnerability exploitation.
 - Exfiltration of data from Mastercard systems.
 - Email spoofing
 - Missing or incorrect SPF/DMARC/DKIM records of any kind
 - Descriptive error messages (e.g., Stack Traces, application or server errors).
 - Fingerprinting / banner disclosure on common/public services.
 - Clickjacking and issues only exploitable through clickjacking.
 - Login/Logout/Unauthenticated/low impact/anonymous user CSRF.
 - Presence of application or web browser 'autocomplete' or 'save password' functionality.
 - Lack of Secure/HTTPOnly flags on non-sensitive Cookies.
 - Lack of Security Speedbump when leaving the site.
 - Weak Captcha / Captcha Bypass
 - Forgot Password page brute force and account lockout not enforced.
 - Username / email enumeration
 - via Login Page error message
 - via Forgot Password error message
 - Any missing/misconfigured HTTP security headers
 - SSL Issues, e.g.
 - SSL Issues, e.g.
 - SSL Attacks such as BEAST, BREACH, Renegotiation attack
 - SSL Forward secrecy not enabled.
 - SSL weak / insecure cipher suites
 - Vulnerabilities affecting users of outdated browsers
 - IE < 9
 - Chrome < 40
 - Firefox < 35
 - Safari < 7, Opera < 13
-